

Northwind Retail Inc.

Data Classification & Handling Policy

Corporate Information Security Policy

Document ID: POL-SEC-004

Version: 3.1

Effective Date: January 15, 2026

Owner: Chief Information Security Officer (CISO)

Review Cycle: Annual, or upon material change to regulatory obligations

1. Purpose

This policy establishes how Northwind Retail Inc. ('the Company') classifies, labels, and handles information assets across their lifecycle. It ensures that data receives a level of protection appropriate to its sensitivity, that employees and partners understand their handling obligations, and that the Company meets its contractual and regulatory obligations regarding data protection.

2. Scope

This policy applies to all information created, received, stored, processed, or transmitted by the Company, regardless of format or location, including documents, emails, databases, and data shared with third parties. It applies to all employees, contractors, and partner organizations with access to Company information.

3. Classification Levels

All Company information must be assigned one of the four classification levels below. The assigned level determines applicable handling, storage, and distribution requirements as described in Section 4.

Level	Definition	Examples
Public	Information approved for unrestricted external release. Disclosure is permitted to the general public.	Press releases, marketing materials, public job postings
Internal	Information intended for use within the Company. Disclosure is limited to employees and contractors.	Internal operations reports, meeting notes, staff directories
Confidential	Sensitive business information that could cause competitive disadvantage if disclosed.	Financial forecasts, product plans, unreleased product roadmaps
Restricted	The highest sensitivity level. Disclosure could cause severe harm to the Company or violate applicable laws.	Customer PII, legal matters, regulatory violations, NDAs, regulated health data

4. Handling Requirements

4.1 Public

May be freely shared externally once approved by the Marketing or Communications team. No encryption or access controls required.

4.2 Internal

Must not be shared outside the Company without manager approval. May be stored on Company-managed systems without additional encryption.

4.3 Confidential

Access limited to employees with a defined business need. Must be stored in access-controlled systems. External sharing requires a signed NDA and approval from the data owner's Director or above.

4.4 Restricted

Access limited to explicitly authorized individuals only. Must be encrypted at rest and in transit. External sharing is permitted only under an active, current NDA that explicitly covers the data category being shared, and requires CISO or Legal approval. Any Restricted data whose governing NDA has expired or been terminated must be immediately re-reviewed and access revoked pending renewal.

5. Partner and NDA Requirements

Data shared with external partners must be governed by an active Non-Disclosure Agreement (NDA) that explicitly names the data categories covered. The Partnerships team maintains the authoritative NDA Registry, recording each partner's relationship tier (Strategic, Standard, or Limited), covered data categories, and NDA effective/expiration dates.

An NDA nearing expiration (within 30 days) must trigger a renewal review. Any document referencing data covered by an NDA must be re-evaluated for reclassification immediately upon that NDA's expiration, renewal, or termination.

6. Data Categories

The following data categories are recognized under this policy and are referenced by the Data-Handling Rules and NDA Registry:

- **Customer PII** — names, contact details, account and transaction history.
- **Financial Data** — internal forecasts, unaudited results, cost and margin data.
- **Internal Operations Data** — logistics, scheduling, and process data with no external party involvement.
- **Regulated Data** — data subject to external regulatory obligations (e.g. GDPR, HIPAA), regardless of partner or NDA status.

7. Regulatory Compliance

Data subject to external regulation is classified Restricted regardless of internal NDA or partner status. Applicable regulations include, but are not limited to, GDPR for EU customer data and equivalent regional data protection laws. The Data Protection and Compliance team maintains records required under applicable regulatory record-keeping obligations (e.g. GDPR Article 30).

8. Roles and Responsibilities

Role	Responsibility
Data Owner	Assigns initial classification; approves external sharing of Confidential and Restricted data.

CISO	Owns this policy; approves Restricted data sharing; oversees re-classification on policy or NDA changes
Partnerships Team	Maintains the NDA Registry and partner relationship tiers.
Data Protection & Compliance	Maintains regulatory record-keeping and flags regulated data categories.
All Employees	Handle data per its assigned classification; report suspected mishandling.

9. Policy Review and Version History

Version	Date	Summary of Changes
1.0	2022-06-01	Initial policy release.
2.0	2023-11-10	Added Partner/NDA requirements section.
3.0	2025-02-20	Added Regulatory Compliance section (GDPR scope).
3.1	2026-01-15	Clarified expired-NDA re-classification requirement.